

The Arzens

Governance, Risk & Compliance (GRC) Internship Project

Phase 1

ISO/IEC 27001:2022

Internal Audit Simulation

Audit Scope Statement & Internal Audit Plan



Usama Arshad

Governance, Risk & Compliance
(GRC) Internship

Lead: Shahal Farid

Co-Lead: Anas Zeeshan



Fictional Organization:
Kohsar Digital Bank (KDB)

Submission Date:

Monday, August 24, 2026

1. Purpose and Scope of This Document

This document establishes Phase 1 (“Audit Planning, Scope Definition, and Audit Criteria”) of the ISO/IEC 27001:2022 Internal Audit Simulation for Kohsar Digital Bank (KDB), as defined in the project proposal. It comprises two deliverables: the Audit Scope Statement and the Internal Audit Plan.

The Phase 1 documents build upon the KDB governance and ISMS artifacts developed during the preceding GRC Advanced Track tasks, including the Information Security Governance Charter, the Policy Hierarchy, the Governance & Risk Escalation Flow, the ISMS design, and the policy architecture reference, as well as the Mini Statement of Applicability (SoA).

Note on organizational scope: Kohsar Digital Bank (KDB) is the fictional organization used for this audit simulation. The simulated audit is scoped to KDB and its defined ISMS boundary.

2. Audit Scope Statement

2.1 Organization and Boundary

The audit covers the Information Security Management System (ISMS) of Kohsar Digital Bank (KDB), within the organizational and operational context defined for this simulation. KDB operates a hybrid cloud model, in which core systems are hosted on-premises, while cloud services are used for disaster recovery and backups. KDB owns and operates a physical data center and develops its core banking and customer-facing software through an internal engineering team. Currently, there are no active outsourced software development contracts within the defined ISMS scope.

2.2 Controls in Scope

The audit encompasses 20 Annex A controls selected in KDB’s Mini Statement of Applicability (SoA), covering all four ISO/IEC 27002:2022 control themes:

- **Organizational — 7 controls:** A.5.7, A.5.9, A.5.10, A.5.15, A.5.19, A.5.23, A.5.24
- **People — 4 controls:** A.6.1, A.6.3, A.6.5, A.6.8
- **Physical — 3 controls:** A.7.1, A.7.4, A.7.7
- **Technological — 6 controls:** A.8.5, A.8.8, A.8.9, A.8.13, A.8.24, A.8.30

The subsequent control assessment therefore evaluates 19 Applicable controls, while A.8.30 is assessed only for continued validity of its Not Applicable determination. Therefore, the audit will assess the implementation and supporting evidence for the 19 Applicable controls and verify the continuing validity and justification for the Not Applicable status of A.8.30.

SoA Count Correction: The SoA cover page currently states a theme breakdown of “6 Organizational, 5 People, 3 Physical, 6 Technological.” However, a row-by-row review of the SoA table confirms the correct breakdown as follows: 7 Organizational, 4 People, 3 Physical, and 6 Technological, totaling 20 controls. This Phase 1 document uses the verified row-level count from the SoA table. The verified breakdown used throughout this audit is 7 Organizational, 4 People, 3 Physical, and 6 Technological, totaling 20 controls.

Control A.8.30 is included in the audit scope to assess whether its Not Applicable determination remains justified by KDB’s defined operating context and whether appropriate supporting evidence exists. Task 7 identifies KDB’s in-house development model and the absence of active outsourced software development contracts as the basis for this determination.

2.3 Management System Clauses in Scope

In addition to the 20 selected Annex A controls, the audit will evaluate conformity with the following ISO/IEC 27001:2022 management system requirements, selected because they are directly represented in KDB's governance and ISMS artifacts included within the audit scope:

- **Clause 5.2 — Information security policy:** assessed against KDB's governance and policy framework.
- **Clause 5.3 — Organizational roles, responsibilities and authorities:** assessed against the Information Security Governance Charter and Decision Rights matrix.
- **Clause 6.1.3 — Information security risk treatment:** assessed through the Statement of Applicability and associated risk-treatment logic.
- **Clause 7.5 — Documented information:** assessed through document control, approval, versioning, and review arrangements represented in the applicable policy and governance artifacts.
- **Clause 8.1 — Operational planning and control:** assessed through implementation and operational evidence associated with the in-scope controls.

2.4 Location and Systems

The audit scope includes the KDB core banking platform, customer information systems, and payment-related systems within the defined ISMS boundary, along with the owned physical data center and the cloud environment used for disaster recovery and backup. KDB office and branch locations are also included where they support the implementation of applicable people and physical security controls, specifically A.6.1, A.6.3, A.6.5, A.6.8, A.7.1, A.7.4, and A.7.7.

2.5 Exclusions

The following are excluded from the audit scope:

- **Outsourced software development:** Currently, no outsourced software development environment falls within the defined KDB ISMS scope. Therefore, A.8.30 will not be tested for implementation. Instead, its Not Applicable determination, justification, and supporting evidence will be reviewed.
- **Other frameworks and scenarios developed during earlier Advanced Track tasks:** NIST CSF 2.0, COBIT 2019, CIS Controls v8, CISA Cybersecurity Performance Goals (CPGs), and the Meridian Financial Group scenario are outside the scope of this ISO/IEC 27001:2022 audit and will not be used as audit criteria.

The audit focuses exclusively on KDB's defined ISMS and the ISO/IEC 27001:2022 requirements and Annex A controls identified in this Phase 1 scope.

2.6 Intended Audience

The audit deliverables are intended for Shahal Farid (GRC Lead) and Anas Zeeshan (GRC Co-Lead), consistent with the governance and reporting responsibilities established in KDB's Governance Charter. The GRC Lead is responsible for governance program execution, while the GRC Co-Lead manages day-to-day governance operations.

3. Audit Objectives

The objectives of the internal audit simulation are to:

- Evaluate the conformity of KDB's ISMS with the applicable ISO/IEC 27001:2022 requirements within the defined audit scope, specifically Clauses 5.2, 5.3, 6.1.3, 7.5, and 8.1.
- Assess the implementation and conformity of the 19 Annex A controls designated as Applicable in KDB's SoA, using the control-specific evidence expectations documented in the SoA.
- Verify the continued validity of the Not Applicable determination for A.8.30 (Outsourced Development), including its justification and supporting evidence.
- Assess conformity with KDB's applicable internal governance and policy requirements that form part of the audit criteria, including the Information Security Governance Charter, Policy Hierarchy, and Access Management Policy.
- Identify conformities, nonconformities, and opportunities for improvement based on objective audit evidence and the defined audit criteria.
- Develop appropriate corrective action recommendations for identified nonconformities, where applicable.

4. Audit Criteria

Audit conclusions and findings will be evaluated against the following defined audit criteria:

- ISO/IEC 27001:2022 requirements applicable to the audit scope, specifically Clauses 5.2, 5.3, 6.1.3, 7.5, and 8.1, as identified in Section 2.3 of this document.
- The 20 Annex A controls identified in KDB's Mini Statement of Applicability (SoA), including the control applicability status, control justifications, assigned owners, and evidence expectations documented therein.
- KDB's Information Security Governance Charter and Decision Rights matrix, where applicable to the governance roles, responsibilities, authorities, and decision-making arrangements being assessed.
- KDB's Policy Hierarchy and Governance & Risk Escalation Flow, where applicable to the governance and escalation requirements within the audit scope.
- KDB's Access Management Policy outline, particularly where it provides organization-specific requirements supporting the assessment of A.5.15.

Audit evidence will be assessed against the applicable criteria above to determine whether the relevant requirement or control is conforming, nonconforming, or presents an opportunity for improvement, based on the objective evidence available within the simulation.

5. Internal Audit Plan

5.1 Roles, Responsibilities, and Independence

This plan adheres to the roles and decision rights defined in KDB's Governance Charter. The table below maps those roles to the activities of this audit.

Role	Audit Responsibility	Basis / Governance Reference
Usama Arshad — Internal Auditor	Plans and conducts the simulated audit; performs document reviews and evidence assessments; documents audit results; prepares findings, nonconformity documentation, and corrective action recommendations.	Assigned assurance role for the simulation; not assigned ownership of the controls being assessed.
Anas Zeeshan — GRC Co-Lead	Reviews audit findings before escalation and provides oversight regarding governance matters arising during the audit.	Governance Charter and Decision Rights matrix.
Shahal Farid — GRC Lead	Reviews the final Internal Audit Report and provides governance oversight for risk acceptance decisions related to unresolved nonconformities, where applicable.	Governance Charter and Decision Rights matrix.
Control Owners — per SoA	Act as auditees for the controls assigned to them; provide or support the provision of relevant evidence and explanations for the controls under their responsibility.	Control ownership and evidence-owner assignments documented in the SoA.
Board / Executive Sponsor	Receives escalated audit matters where the defined escalation criteria require executive-level involvement.	Governance & Risk Escalation Flow.

Independence and Objectivity Note: This is a simulated internal audit. Usama Arshad performs the Internal Auditor role and has also contributed to the preparation of several KDB artifacts that may be examined during the simulation, including the SoA and supporting policy documentation. In a real Information Security Management System (ISMS), auditor independence and objectivity must be maintained, including avoiding the auditing of one's own work. This limitation in the simulation is disclosed in advance and will be taken into account when evaluating the reliability and objectivity of audit conclusions. It will not alone be recorded as a KDB nonconformity unless the simulation explicitly treats the auditor-independence issue as an audit finding.

5.2 Audit Schedule

The project will be executed through four sequential phases, with the detailed working schedule managed according to project progress and the availability of required information and evidence.

Phase	Primary Activity	Key Deliverables
Phase 1	Audit planning, scope definition, and audit criteria	Audit Scope Statement; Internal Audit Plan
Phase 2	Documentation review and audit checklist preparation	Internal Audit Checklist
Phase 3	Control assessment, evidence collection, and audit findings	Audit Evidence Log; Audit Findings Register
Phase 4	Corrective action recommendations and final reporting	Nonconformity Report; Corrective Action Recommendations; Executive Summary; Final Internal Audit Report

5.3 Resources and Methods

The simulated audit will utilize the following methods:

- **Document review:** A review of the Information Security Governance Charter, Policy Hierarchy and Governance & Risk Escalation Flow, ISMS design and policy architecture reference, Access Management Policy outline, and Mini Statement of Applicability (SoA).
- **Simulated interviews:** Structured interview questions will be developed for the relevant control owners identified in the SoA. Simulated responses will be clearly identified as simulated and documented with their source, control association, and date of preparation.
- **Simulated technical evidence:** Illustrative artifacts, such as mock access-review exports, mock vulnerability-scan summaries, configuration extracts, or other control-specific evidence, may be developed as required by the SoA evidence expectations. Such artifacts will be clearly labeled as simulated evidence and will not be represented as evidence obtained from a real KDB environment.
- **Sampling:** When a control involves a defined population, such as user accounts or access-review records, an appropriate sample size, selection method, and sampling rationale will be documented in the Audit Evidence Log. Testing will not automatically be treated as exhaustive unless explicitly stated.
- **Evidence evaluation:** Evidence will be assessed for relevance, sufficiency, consistency, and traceability to the applicable audit criteria before an audit conclusion is recorded.

5.4 Reporting and Distribution Plan

Audit results will be consolidated in the Audit Findings Register and, where applicable, documented through Nonconformity Reports and Corrective Action Recommendations during Phases 3 and 4. The Final Internal Audit Report and Executive Summary will be prepared for review by Shahal Farid (GRC Lead) and Anas Zeeshan (GRC Co-Lead) in accordance with the established governance and reporting structure.

If an audit matter meets the escalation criteria defined in KDB's Governance & Risk Escalation Flow, it will be escalated through the appropriate governance channel without waiting for the completion of the final report.

Audit conclusions and recommendations will be supported by documented evidence and will clearly distinguish between conformities, nonconformities, and opportunities for improvement.

6. Evidence Management and Simulation Approach

Since this is a simulated internal audit rather than an audit of a live KDB environment, evidence will be developed using clearly identified simulated artifacts where direct organizational evidence is unavailable.

Evidence used during the simulation may include:

- Existing KDB governance and ISMS artifacts developed during the GRC Advanced Track.
- Simulated interview responses based on the control owners and responsibilities defined in the SoA.
- Illustrative document excerpts and records.
- Simulated system or management reports, such as access-review records or vulnerability-scan summaries.
- Other control-specific artifacts developed to represent the evidence types identified in the SoA.

All simulated evidence will be clearly labeled and traceable to the relevant control, audit criterion, and evidence requirement. Simulated artifacts will not be represented as evidence obtained from an actual production environment.

Evidence and simulated auditee responses will be reviewed for relevance, consistency, sufficiency, and traceability before they are entered into the Audit Evidence Log and used to support an audit conclusion. If evidence is insufficient to support a conformity conclusion, the limitation will be documented rather than resolved through unsupported assumptions.

- End of Phase 1 -